

SecOps Lab

Lab Assignment: Investigator OPSEC — Persona, Footprint & Disposable Environment

Duration: 3h30 (afternoon lab, Day 1) **Prerequisite:** Day 1 morning (threat model, attribution postures, fingerprinting).

Learning Objectives

By the end of this lab, you will be able to:

- Write a **threat model** for an investigation and derive a *proportionate* protection level.
- Build, start and destroy a **disposable OSINT container** (Docker) with a neutral identity (hostname, UTC, locale) and a **Tor** exit.
- Prove, with commands, what your environment leaks (IP, DNS, timezone, metadata, browser fingerprint) and fix it.
- Generate a **coherent research persona**, check it for **collisions** and plan its ageing and compartmentalisation.
- Audit and **reduce your own digital footprint** (handles, emails, passwords, metadata).
- Run a fully **documented browsing session with Hunchly** (case, selectors, notes, hashed captures, exportable report).

Scenario

You are a junior analyst at a threat-intelligence firm. Case **CASE-042**: a handle on a public forum is advertising a database allegedly stolen from a European retailer. Your team lead wants you to *prepare* the investigation. The seller is known to check who views their profiles and has doxxed a researcher in the past.

Rule for this lab: you prepare and test the setup. You do **not** contact, follow or search the real seller. Every test in this lab targets neutral sites or your own persona. Creating social-media accounts with the persona is **out of scope** (legal frame, Day 1 morning): only the mailbox may be created, with instructor approval.

Ground rules

- Work in pairs. One drives, the other logs every command and output in the environment report.
- **Never** log into a personal account from the case environment or the persona browser profile.

- Everything you produce goes into the case workspace (`~/osint-cases/CASE-042/`), nowhere else.

Step 0 — Setup (15 min)

You need on your **host** machine:

Component	Why	Install
Docker Desktop (or Docker Engine on Linux)	run the disposable container	https://docs.docker.com/get-docker/
Python 3.10+	lab scripts	already present on macOS/Linux, https://python.org on Windows
<code>pipx</code>	isolated install of CLI tools	<code>python3 -m pip install --user pipx && python3 -m pipx ensurepath</code>
<code>sherlock</code> , <code>holehe</code>	handle / email pivot tools	<code>pipx install sherlock-project</code> then <code>pipx install holehe</code>
<code>exiftool</code>	metadata	<code>brew install exiftool</code> / <code>sudo apt install libimage-exiftool-perl</code>
Chrome, Edge or Brave	Hunchly extension	any Chromium browser
Hunchly	evidence capture	https://www.hunch.ly — 30-day trial, no credit card (Classic licence ≈ 149 €/year)

Copy the `scripts/` and `templates/` folders of this lab to a working directory, then:

```
cd scripts
python3 -m venv .venv && source .venv/bin/activate      # Windows:
.venv\Scripts\activate
pip install faker requests
chmod +x *.sh *.py
```

Deliverable check: `python3 persona_forge.py --list-locales` prints the locale table.

Step 1 — Threat model first (20 min)

Open `templates/threat_model_opsec_note.md` and fill it for CASE-042. Discuss with your partner, then write it down. Nothing technical is allowed before this page is complete.

Guiding questions

1.1 Who is the adversary here, and how much effort will they invest to identify you? Justify with the scenario.

1.2 What is the *worst* consequence of being identified: for you, for the case, for the client?

1.3 Which attribution posture do you choose (non-attribution / managed attribution / attribution)? Why is the other one wrong here?

1.4 For each layer (machine, network exit, browser, identity, evidence capture, data at rest) write one line: decision + rationale. Name explicitly one trade-off you accept.

Methodology tip: OPSEC is proportionate, not maximal. "Tor for everything" is a valid answer only if you can explain why a VPN is insufficient *for this adversary*.

Step 2 — The disposable environment (60 min)

2.1 Why a container, and a word about Exegol

The morning slides list three isolation strategies: burner VMs restored from snapshot, dedicated browsers, one network exit per identity. A Docker container gives you the "burner VM" property at almost no cost: an **image** is your clean snapshot, a **container** started with `--rm` is destroyed when you leave, and a **volume** is the only thing that survives.

You may have heard of **Exegol** (<https://exegol.com>), a popular wrapper that manages hardened pentest/OSINT containers with one command (`exegol start`). It is a good tool and its options (`--vpn`, `--hostname`, `--disable-shared-timezones`, `--desktop`, shell logging with `-l`) implement exactly the OPSEC ideas of this lab. We do **not** use it today for two reasons: the free *Community* edition only ships the 42 GB `free` image, the dedicated `osint` image being reserved to paid tiers, and above all **you learn more by building the container yourself**: every line of the Dockerfile is an OPSEC decision you can defend.

2.2 Read the Dockerfile before building it

Open `scripts/Dockerfile.osint` and `scripts/entrypoint.sh`. Answer in your environment report:

2.2.a Which three environment variables neutralise the regional footprint? What would leak if they were missing?

2.2.b Why is the user `analyst` and not `root`? Why is `HISTFILE=/dev/null`?

2.2.c What does `proxy_dns` in `proxychains4.conf` prevent?

2.2.d Find the sentence "the image itself is a fingerprint too". Give one concrete example of how a custom image could identify its author.

2.3 Build and start the case container

```
cd scripts
docker build -t osint-lab:latest -f Dockerfile.osint .          # ~5 min, ~2 GB
./osint_case.sh start CASE-042
```

You are now inside the container, in `/workspace` (mounted from `~/osint-cases/CASE-042/` on the host). Tor was started by the entrypoint.

Run **inside** the container:

```
hostname ; date ; echo $LANG ; whoami
curl -s https://ipinfo.io/json          # direct exit
tcurl https://check.torproject.org/api/ip # alias: curl via Tor
SOCKS
cat /etc/resolv.conf
./opsec_check.sh --home-country FR --expect-tor
```

2.3.a Compare `hostname`, `date` and `$LANG` with the same commands on your **host**. What changed and why does it matter?

2.3.b Copy the `opsec_check.sh` output in the environment report. Is it GO or NO-GO? If NO-GO, fix and re-run until GO. Explain each fix.

2.3.c The direct exit IP is your real connection (or your VPN). Which of your tools will use it by default? How do you force one of them through Tor? Test with:

```
torsocks sherlock someusername --print-found --no-txt --timeout 10
proxychains4 -q holehe test@example.com --only-used
```

2.4 Prove the "disposable" property

Inside the container:

```
echo "secret note" > /tmp/scratch.txt
echo "case note" > /workspace/notes/first.md
exit
```

Then on the host: `./osint_case.sh start CASE-042` again, and check both files.

2.4.a Which file survived? Which one did not? Relate this to the "snapshot" concept of the slides.

2.4.b Read `osint_case.sh`. List the `docker run` flags that implement: least privilege, neutral hostname, disposability, persistence of evidence. Which flag would you add to route **all** container traffic through a VPN, and what capability does it require?

2.5 Browser fingerprint (host side, dedicated profile)

The container has no GUI browser: browsing happens on the host, in a **dedicated browser profile** for the persona (Chrome: *Profiles* → *Add*; Firefox: `about:profiles`; or Tor Browser).

From the persona profile **only**, visit:

- <https://coveryourtracks.eff.org> → note "unique / nearly unique / not unique" and the bits of identifying information.
- <https://amiunique.org> → note the uniqueness verdict and the 3 most identifying attributes.
- <https://browserleaks.com/webrtc> → is a local or public IP leaked?

2.5.a Fill the fingerprint table of the environment report. Which attributes betray your *real* location or language even though the IP is hidden?

2.5.b Do the same test in Tor Browser. Why is the fingerprint "less unique" there? What is the trade-off?

2.5.c Fix at least two attributes in the persona profile (timezone / language / WebRTC / canvas). Re-test and document the delta.

Step 3 — Build the persona (45 min)

3.1 Generate a coherent legend

```
python3 persona_forge.py --locale de_DE --case CASE-042 --check
```

Read the generated `personas/<username>.md`.

3.1.a Why did the script pick a **German** timezone, language and email provider together? What happens to the persona if only one of these three is inconsistent?

3.1.b The `--check` option ran `sherlock`. Read the "found on" list critically: open two of the URLs. Are they real accounts? What do you conclude about automated handle checks?

3.1.c Regenerate until you get a handle with **zero confirmed** collision. Keep the JSON of the persona you retain.

3.2 Password and email hygiene

```
python3 footprint_audit.py --mode persona --username <handle> --password-prompt
```

Type a password you *would* have used (e.g. `Winter2024!`), then a generated one.

3.2.a How many times was the first one seen in breaches? Explain in one sentence how the k-anonymity query works (what leaves your machine, what does not).

3.2.b With instructor approval, create the persona mailbox **from the persona browser profile, through the persona exit**. Then run `footprint_audit.py --mode persona --email <address>`. What should `holehe` return for a brand-new address? Re-run in 30 days: what should it return then?

3.3 Compartmentalisation and ageing

3.3.a Complete section 3 (compartmentalisation) of the persona sheet with your *actual* choices: which exit, which browser profile, which container name.

3.3.b Write the first four entries of the **persona log** (section 5) for the ageing plan. Include date in UTC, platform, action, exit IP country.

3.3.c List three behavioural signals (hours, language, typos, reactions...) that would betray a French analyst behind a German persona. How does the persona sheet help you avoid them?

Fatal error reminder: logging into a persona from your real IP once is enough. Correlation happens at the weakest link.

Step 4 — Reduce your own footprint (30 min)

A persona is only as safe as the analyst behind it. Now turn the tools on **yourself** (your own data, your consent).

```
python3 footprint_audit.py --mode real --username <your usual handle> --email <your email> --out ../exports/me.md
```

Also, in a private window: search your handle and full name on Google, Bing and Yandex; check <https://haveibeenpwned.com> with your email; reverse-image-search your most used profile photo (Google Lens, Yandex).

4.1 Fill `templates/footprint_reduction_plan.md`: inventory, decision per item, structural fixes.

4.2 Identify at least **one pivot** from your professional identity to a personal account (shared handle, shared photo, shared email). How would an adversary use it?

4.3 Metadata. Put two files you would realistically share (a photo taken with your phone, a PDF you exported) into `~/osint-cases/CASE-042/exports/`, then inside the container:

```
./opsec_check.sh --scan-dir /workspace/exports
exiftool -all= -overwrite_original /workspace/exports/*.jpg
mat2 /workspace/exports/*.pdf
./opsec_check.sh --scan-dir /workspace/exports
```

Paste before/after. Which fields were the most dangerous?

Step 5 — Hunchly: a browsing session you can defend (40 min)

Hunchly is a browser extension plus a local dashboard. Once a case is active, **every page you visit is captured**: URL, timestamp, full-page screenshot and a hash, so the capture can later be produced as evidence. Selectors (names, handles, emails) are highlighted automatically on every page.

5.1 Install and create the case

1. Create a trial account at <https://www.hunch.ly> with the **persona mailbox** or a team mailbox, never your personal one.
2. Install the Hunchly dashboard (Windows/macOS/Linux) and the browser extension **in the persona browser profile only**.
3. Dashboard → *New case* → name it `CASE-042` (never the target's name).
4. Extension → select the case → toggle capture **ON** (icon turns green).
5. Add selectors: your persona handle, the string `OSINT`, one fake email `seller042@example.com`.

5.2 Run a controlled session (neutral targets)

With capture ON and the exit verified (Step 2), browse:

- https://en.wikipedia.org/wiki/Open-source_intelligence
- <https://check.torproject.org>
- a search-engine query for your **persona** handle (results page)
- <https://www.bellingcat.com> (one article of your choice)

On at least three pages: add a **note** (why this page matters, confidence), and a **tag** (`identity`, `infra`, `to-verify`). Download one image from an article: it must appear in the case *Photos*.

Then toggle capture **OFF** and open your personal webmail. Check the dashboard.

5.2.a How many pages were captured? Was the webmail captured? What does that tell you about the discipline of toggling?

5.2.b Open one capture: which metadata are stored (URL, time, hash...)? Why does a hash matter for chain of custody?

5.2.c Where are the selectors highlighted? Give one case where automatic highlighting saved you a manual search.

5.3 Export and seal

1. Dashboard → *Export* → report (Word or HTML) → save into `~/osint-cases/CASE-042/exports/`.
2. Inside the container: `sha256sum /workspace/exports/<report>` and write the hash + UTC time into `/workspace/notes/case_log.md`.
3. Run `./opsec_check.sh --scan-dir /workspace/exports` once more: does the Hunchly export itself leak metadata about you?

5.3.a Complete `templates/hunchly_case_checklist.md` and tick what you actually did.

Step 6 — Teardown (10 min)

```
exit                                # leaves and destroys the container (--rm)
./osint_case.sh purge CASE-042      # confirms nothing is left
docker ps -a | grep osint           # must be empty
```

6.1 What remains on disk after teardown? Where? Who can read it? Propose one measure (encryption / retention) and add it to the OPSEC note.

Submission Deliverables

Submit a single zip archive `CASE-042_<pair>.zip` containing:

1. **OPSEC note** (`threat_model_opsec_note.md`, completed): threat model, posture, countermeasures, accepted trade-offs.
2. **Environment report** (`environment_report.md`): real command outputs, GO/NO-GO of `opsec_check.sh`, fingerprint table before/after.
3. **Persona sheet** (`personas/<handle>.md` + `.json`) with collision check evidence and the first four ageing-log entries.
4. **Footprint reduction plan** (`footprint_reduction_plan.md`) + `exports/me.md` (anonymise anything you do not want the instructor to see).
5. **Hunchly export** (Word/HTML) + `notes/case_log.md` with its SHA-256, + completed checklist.
6. **Answers** to the numbered questions (1.1 → 6.1) in a short Markdown or PDF.

Grading grid (100 pts)

Item	Points	What earns the points
Threat model & posture	15	proportionate, justified, explicit trade-off
Container understanding	20	Dockerfile questions, GO result, disposability proven
Fingerprint & network	15	table filled, real fix with measured delta
Persona	20	coherence, verified collision check, ageing log, compartmentalisation
Own footprint	10	honest inventory, one pivot identified, metadata before/after
Hunchly	15	case, selectors, notes/tags, export hashed, discipline question
Report quality	5	reproducible commands, no personal data leaked in the archive

Any personal credential, real IP or unmasked personal email left in the archive costs 10 points. OPSEC applies to your homework too.

Optional Extensions (Bonus)

- **VPN → Tor chain inside the container:** start the container with `--cap-add NET_ADMIN --device /dev/net/tun`, bring up a WireGuard config, and prove with `opsec_check.sh` that direct traffic exits via the VPN while `tcurl` exits via Tor.
- **Hardened Firefox profile:** apply the `arkenfox user.js` to the persona profile and measure the fingerprint delta on coveryourtracks.
- **Shell logging for chain of custody:** record every container session with `script` or `asciinema` into `/workspace/logs/` (this is what Exegol's `-l` option does). Discuss what you must redact before sharing a log.
- **Automate the environment report:** extend `opsec_check.sh` with a `--json` output and a small Python script that fills `environment_report.md` automatically.
- **Persona ageing bot, ethically:** write the *design* (not the code) of a scheduler that would produce human-like activity for the persona. List the legal and platform-ToS constraints that stop you from actually running it.